

The Gap Nobody Talks About

Prepared for HMH — explained with one real scenario

What This Slide Is Saying

Think of your API gateway (APIM, Kong, or any other) like a **security guard at a building entrance**. The guard checks badges, enforces visitor limits, and follows the rules posted on the wall. That's the **green side** — your gateway already does this well.

But here's the question: **who writes those rules on the wall?** Who makes sure the rules are correct? Who updates them when threats change? Who checks that every entrance in every building has the same rules? That's the **red side** — and today, **nobody owns that job**.

What your gateway already does ■

- Checks every API call against your rules
- Blocks too many requests (rate limiting)
- Verifies user identity (tokens)
- Controls who can call from where
- Reshapes requests and responses

What nobody is doing today ■

- Who writes the security rules correctly?
- Who knows which threats to protect against?
- Who explains what each rule does and why?
- Who keeps rules consistent across 50+ APIs?
- Who tracks every change and who approved it?

Your gateway is the guard. GitHub Copilot is the person who writes, reviews, and improves the rulebook.

One Real Scenario for HMH

Situation: A developer at HMH needs to add a new API for a partner integration. They need security rules (an XML policy) that validate tokens, limit request rates, and block common attacks. Today this developer either:

- Copies an old policy and hopes it's still correct, or
- Writes one from scratch and misses something, or
- Waits days for a security review that may never happen.

With GitHub Copilot filling the gap:

1. Developer asks Copilot: "Write me an APIM policy for a partner API that needs OAuth, rate limiting at 100 calls/min, and CORS for our portal."
2. Copilot generates the correct XML policy, explains each section, and flags which OWASP threats it covers.

3. Developer submits a Pull Request. An automated scanner checks the policy against 18 security rules — **before it ever reaches production.**

4. If something is wrong (e.g., missing rate limit), the PR is blocked and Copilot suggests the fix — right in the code review.

5. Every change is tracked in Git: who changed what, when, and who approved it. Full audit trail, forever.

Result: The new API goes live in hours instead of days, with the right security from the start, reviewed by both AI and humans, and fully auditable.

Bottom line: Your gateway protects APIs at runtime.

GitHub Copilot protects the *process* of writing, reviewing, and maintaining those protections.